

File No.: EXP202307120

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on April 10, 2023. The complaint is directed against the NATIONAL INSTITUTE OF SOCIAL SECURITY with NIF Q2827002C. The reasons for the complaint are as follows:

The National Institute of Social Security sent the claimant the documentation of their retirement file.

Among this documentation is an official letter containing the data of another citizen.

According to the claimant, there has been a transfer of personal data between files, the extent of which is unknown.

Along with the complaint, the claimant provides a copy of their file and the official letter addressed to another person.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to the National Institute of Social Security for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on June 2, 2023, as stated in the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

THIRD: On July 10, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

FOURTH: On November 20, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

FIFTH: After notifying the aforementioned initiation agreement in accordance with the rules established in the LPACAP, the respondent submitted a written statement on November 30, 2023, in which, in summary, they made the following allegations:

- In the Initiation Agreement of the Sanctioning Procedure, it is stated that the AEPD did not receive a response to the forwarding letter of the complaint filed with said agency by the claimant, and they assert that this is not true, since the INSS made the initial declaration of the security breach to the AEPD, sent informative letters about the situation that occurred both to the claimant who received the documentation of another citizen by mistake, and to the affected party, the holder of the data subject to the security breach.

- The INSS received notification from the AEPD communicating the following: "After analyzing the additional information provided, the breach has been updated in the register of notifications of personal data breaches and, without prejudice to the course of other proceedings, no further actions are planned by this Division in relation to this notification of personal data breach." The Institute understood that no further action was necessary.

- The INSS has continued to adopt various measures in data protection, such as awareness actions, publications, instructions, training actions, preparation of consultation materials, as well as informing and raising awareness about the concept of security breach and the need to communicate it to the

Data Protection Subdelegate of the INSS to all its staff.

- The Entity has prepared and disseminated an informative brief that is currently published on its corporate intranet.
- It has proceeded to automate most of the communications issued by the Institute and is carrying out, in a centralized manner, through the computer management applications used in processing its benefits, without direct intervention from personnel assigned to this entity (SARTIDO printing train - documentary manager of the INSS), with the consequent decrease in the probability of human errors occurring.
- It has been a specific human error for which this Entity already adopts numerous measures, both preventive and reparative.

SIXTH: On April 25, 2024, a proposal for resolution was formulated in which all the allegations raised were addressed, and the declaration of infringement for non-compliance with Articles 5.1.f) and 32 of the GDPR was proposed. The proposal was duly notified on April 25, 2024, as stated in the acknowledgment of receipt in the file.

Regarding the response to the allegations presented against the initiation agreement, the Agency stated in the proposal for resolution:

In response to the assertion that it is not true that no response was given to the forwarding letter of the complaint, it should be explained that what the INSS has done is

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

to carry out an initial communication of a security breach, but not to respond to the written transfer of claim and request for information dated 30/05/2023, in which a one-month deadline was given to send all the documentation and information requested.

Regarding the fact that the INSS received notification from the AEPD communicating the following:

“After analyzing the additional information provided, the breach has been updated in the register of notifications of personal data breaches and, without prejudice to the course of other procedures, no further actions are anticipated from this Division regarding this notification of personal data breach,” it understood that no additional action was necessary. It should be noted that this interpretation cannot be accepted since the aforementioned document is generically signed by the AEPD, comes from the Division of Technological Innovation, which is responsible for receiving security breaches and registering them accordingly. It is not signed by the Director of the Agency, does not contain a dispositive part in which something is agreed or resolved, nor does it indicate any appeal against it. Therefore, the document does not have a decisional character; it is rather an “acknowledgment of receipt” of the notified breach and cannot be understood to mean that this AEPD has assessed and decided that there was no responsibility for a supposed breach of data protection regulations. It also does not formally reflect a decision or a resolution to archive any action, as the only competent body for this is the current Director of the AEPD.

Regarding the rest of the allegations in which it is stated that various measures are being implemented in the field of data protection and that it was a specific human error for which the INSS is already adopting numerous measures, both preventive and remedial, it should be noted that, although this Agency positively values the adoption of new measures that lead to greater security concerning the processing of personal data and that may prevent, in the future, incidents like the one at issue in this procedure, security measures must be adopted with regard to all and each of the risks present in the processing of personal data, including the human factor.

SEVENTH: No written allegations have been received by this Agency regarding the proposed resolution.

From the actions carried out in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: The complainant received documentation from the entity being complained about related to their retirement file.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/10

SECOND: Among this documentation is a letter related to the file of another citizen, which includes their name and surname, postal address, and the subject of that file.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Considerations

In this case, there is evidence of the processing of personal data by the INSS in its activity, as established in Article 4.2 of the GDPR:

"‘processing’: any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of making available, alignment, combination, restriction, erasure, or destruction."

The INSS carries out this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR:

"‘data controller’ or ‘controller’: the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided for by the law of the Union or of the Member States."

III

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/10

Unfulfilled Obligation

The known facts constitute an infringement attributable to the INSS, regulated in Article 5.1.f) of the GDPR and another infringement of Article 32 of the GDPR.

IV

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

The principles relating to processing are, on one hand, the starting point and the closing clause of the

legal framework for data protection, constituting true guiding rules of the system with intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

This principle assigns to the controller of any processing of personal data the obligation, the guarantee, to prevent unauthorized or unlawful processing of such data, as well as their loss or destruction. In other words, a data controller must not process personal data if they are not in a position to guarantee the confidentiality and integrity of such data and prevent a third party from accessing data that does not concern them, as well as avoid their loss or destruction.

In this case, the claiming party receives among the documentation of their file an official letter addressed to another citizen, that is, there has been a transfer of documentation between different parties without knowing the extent of it.

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the National Institute of Social Security has violated the principle of confidentiality by failing to adopt the required technical and organizational measures of all kinds mandated by the regulations on the protection of personal data that would ensure that unauthorized third parties do not have access to personal data, and therefore this fact is considered to constitute an infringement for violation of Article 5.1.f) of the GDPR.

VI

Classification of the infringement of Article 5.1.f) of the GDPR

Article 83.5.a) of the GDPR classifies as an administrative infringement any violation of “the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/10

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that:

“Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall be subject to a three-year statute of limitations, particularly the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

VII

Article 32 of the GDPR

Article 32 “Security of processing” of the GDPR states:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. When assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/10

have access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law.”

This article of the GDPR obliges the controller to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects. This necessarily implies an examination of each processing operation by the controller and the obligation to design appropriate technical and organizational means, with their correct implementation and appropriate use also being necessary, so that they will also be liable for a lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case. In this case, the National Institute of Social Security sent documentation containing personal data of another citizen to the claimant, which is considered a failure to implement appropriate technical and organizational security measures concerning the use of personal data based on the estimated potential risks.

In accordance with the evidence available in this resolution of the sanctioning procedure, it is considered that the facts constitute an infringement for violation of Article 32 of the GDPR.

VIII

Classification of the infringement of Article 32 of the GDPR

Article 83.4.a) of the GDPR classifies as an administrative infringement any violation of “the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.”

In this regard, the LOPDGDD, in its Article 71 “Infringements,” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and will be subject to a two-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.” (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/10

IX

Sanction for the infringements of Articles 5.1.f) and 32 of the GDPR

Article 83 “General conditions for the imposition of administrative fines” of the GDPR, paragraph 7, establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Furthermore, Article 77 “Applicable regime for certain categories of controllers or processors” of the LOPDGDD provides as follows:

1. The regime established in this article shall apply to the processing for which they are responsible or for which they are processors:

(...)

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that comprise the Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures to be adopted to cease the conduct or correct the effects of the infringement that has been committed, except for that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which they are hierarchically subordinate, where applicable, and to the affected parties who had the status of data subjects, where applicable.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs must be communicated to the data protection authority.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

5. The actions taken and the resolutions issued under this article will be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it will publish on its website, with due separation, the resolutions related to the entities mentioned in section 1 of this article, with an explicit indication of the identity of the data controller or processor that committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions will be governed by its specific regulations.

This provision excludes the imposition of administrative fines when the infringements referred to in articles 72 to 74 of the LOPDGDD are committed by the categories of data controllers or processors listed in section 1 of the aforementioned article 77, establishing that the procedures arising from violations of personal data protection regulations committed by those entities will be resolved by declaring the infringements.

X

Adoption of measures

The text of the resolution establishes what the infringements committed were and the facts that led to the violation of data protection regulations, from which it is clearly inferred what measures are to be

adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

The party being addressed in its response dated 30/11/2023 has indicated that it has adopted specific measures to attempt to prevent incidents like those that led to this file through publications, instructions, training actions, preparation of consultation material, and raising awareness among its processors about the importance of reviewing the recipients of communications, as well as their correspondence with the documentation or information that contains personal data and is sent externally.

On the other hand, it has proceeded to automate most of the communications issued through the management software applications used in processing its services without direct intervention from personnel assigned to the entity, thereby reducing the likelihood of human errors occurring.

For all these reasons, this Agency considers the measures adopted by the entity to be adequate regarding the analysis of processes in which it is possible to avoid the intervention of the human factor so that they are developed in an automated manner and reduce, as much as possible, the probabilities of these human errors.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/10

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that the NATIONAL INSTITUTE OF SOCIAL SECURITY, with NIF Q2827002C, has infringed the provisions of articles 5.1.f) and 32 of the GDPR classified under article 83.5 and 83.4, respectively.

SECOND: TO NOTIFY this resolution to the NATIONAL INSTITUTE OF SOCIAL SECURITY.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of article 77.5 of the LOPDGDD.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024
Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es